

TD 2 : Utilisation distante SSH et Gérer une IPC via une AC

1 Secure Shell

Dans cette partie, nous allons réviser les commandes de connexion à distance via SSH. Vous pourrez à titre informatif, et/ou culturel, chercher l'équivalent de chaque commande sous MacOS et/ou Windows. OpenSSH est un outil de connexion à distance composé d'un client («ssh» sous unix, «putty» sous Windows, ...) et d'un serveur («sshd» sous Linux). Les fichiers de configuration d'OpenSSH se trouvent dans le répertoire «/etc/ssh/». Les fichiers de personnalisation du client se trouvent dans le homedir de l'utilisateur, dans le répertoire «.ssh/».

Après vous être documenté sur internet, expliquer rapidement comment fonctionne la connexion d'un client SSH sur un serveur. Pourquoi peut-on dire que ce protocole est sécurisé ?

1.1 Premières utilisations

La syntaxe de l'utilisation du client «ssh» est la suivante :

```
ssh [ options ] [ login@hostname ] [ commande ]
```

Si le fichier «~/ssh/known_hosts» existe, renommez-le :

```
mv ~/.ssh/known_hosts{,.old}
```

Expliquez la syntaxe proposée ci-dessus.

Connectez vous au serveur SSH du département. Que ce passe-t-il ? Expliquez.

Exécuter la commande suivante :

```
sed -i 's/.\{5\}$/aaaa/' ~/.ssh/known_hosts
```

Que fait cette commande ? 这个命令使用sed编辑器在~/.ssh/known_hosts文件中，将每行的最后五个字符替换为aaaaa。

Se reconnecter au serveur. Que se passe-t-il ? Pourquoi ?

Utiliser «ssh-keygen» pour solutionner ce problème.

ssh-keygen生成新的密钥对（公钥和私钥）

1.2 Génération d'une clef asymétrique

NB : Vous verrez en détail le fonctionnement du chiffage par clé dans le cours de crypto du second semestre.

passphrase 密码短语，私钥的锁

OpenSSH est une implémentation du protocole SSH. Cette implémentation est open source et est libre sous Linux. Elle utilise la commande «ssh-keygen» pour générer les clefs asymétriques. Utiliser la commande «man» pour trouver comment fonctionne la génération de clef.

Vous verrez qu'il vous est demandé, à la fin de la génération de la clef, une «passphrase». La passphrase est un secret qui sera utilisée avec un cryptosystème symétrique.

— Générez deux clefs asymétriques, l'une avec une passphrase, l'autre sans, respectivement dans les fichiers «secure» et «unsecure» de votre répertoire de configuration de «SSH».

- Identifiez la partie publique et la partie privée du secret asymétrique en regardant le contenu des fichiers.
- Déterminez quelle partie de la clé est chiffrée. A quoi sert-il de chiffrer cette partie de la clé asymétrique ?
- Pourquoi pas les deux parties ?
- Que se passe-t-il si vous perdez la passphrase ?

如果你丢失了密码短语，那么即使有私钥也无法使用，因为解密私钥需要密码短语。

1.3 Authentification par clés

Une façon de voir le cryptosystème asymétrique est d'imaginer que la partie publique de la clé est une serrure et que la partie privée est la clé de cette serrure.

La mise en place de l'authentification par clés consiste à déposer, sur votre compte, dans votre répertoire «.ssh/», à l'intérieur du fichier «authorized_keys», la partie publique de la clé (la serrure).

Nous précisons ensuite au programme ssh quelle clé utiliser pour déverrouiller la serrure. L'accès à la clé est protégée ou non par mot de passe.

- Déployez vos clés publiques (générées précédemment) dans votre homedir (en une seule commande) ;
- votre home étant distribué, essayez d'accéder au serveur ssh du département (SSH, ssh.ufr-info-p6.jussieu.fr). Analysez ce qui se passe et corrigez la commande en cas de besoin.
- que fait la commande «ssh-keygen -l -f unsecure» ? et «ssh-keygen -l -f unsecure.pub» ? A quoi sert cette sortie ?

命令显示指定文件（在这个例子中是未加密的私钥文件）的指纹

显示的是公钥文件的指纹

指纹-密钥的哈希标识符

1.4 Personnalisation de ssh

Il est possible de modifier un certain nombre de paramètres de fonctionnement d'OpenSSH via le fichier «~/.ssh/config».

La page de manuel de «ssh_config» donne une liste des options disponibles.

Générer un fichier de configuration permettant de se connecter au serveur SSH en utilisant l'alias «secure» pour utiliser la clé protégée par mot de passe et l'alias «unsecure» pour utiliser la clé non protégée. Tester ces configurations.

Tester la configuration .

1.5 Utilisation d'un porte clés

Il est possible de gérer les clefs OpenSSH asymétriques avec un porte clef nommé «ssh-agent». Ce dernier maintient les clefs en mémoire pour éviter de devoir les recharger et éviter la resaisie de la «passphrase».

Quelles sont les dés/avantages de charger une clef en mémoire ?

Lancez l'agent et exportez les variables dans votre environnement. Trouvez comment ajouter une clef au porte clef. Utilisez le porte clef pour faire une connexion SSH.

方便性：一旦私钥被加载到ssh-agent中，就无需再次输入密码短语，这使得频繁的SSH连接更加便捷。
安全性：私钥从不以明文形式存储在磁盘上，只在内存中，减少了被盗风险。

缺点：
安全隐患：如果攻击者获得对运行ssh-agent的系统的访问权限，他们可能能够使用存储在内存中的私钥。
内存使用：对于运行在资源受限的系统上，ssh-agent可能会消耗宝贵的内存资源。

1.6 Différents modes de connexions

Vous verrez en détail en deuxième année le fonctionnement du réseau dans le cours «réseaux». En attendant, imaginez une machine connectée au réseau comme un gros bloc de 65535 prises. Ces prises sont appelées en terminologie réseau, des ports. Un programme pouvant être accédé par le réseau utilise une prise. On dit qu'il «écoute» sur un port. Sauf cas particulier, un port ne peut-être utilisé que par un programme à la fois. Les 1024 premiers ports sont réservés pour le système. Vous pouvez utiliser les autres ports. Un certain nombre de ports sont réservés pour des services particuliers, par exemple, le port 22 est réservé pour SSH, le port 80 est réservé pour le protocole http, le port 443 l'est pour le protocole https, etc... Lorsque nous utiliserons des ports pour les redirections de ports, ils devront donc «être libre», c'est à dire qu'aucun programme ne les utilisera déjà, et non réservés, donc supérieurs à 1024.

Les techniques évoquées ci dessous vous permettront de vous connecter sur un réseau depuis un autre au travers d'une machine accessible en SSH.

1.6.1 Connexion par rebond 无跳板 (Pivot) 连接

Se connecter à une machine située dans un réseau local peut s'illustrer par la figure 1 page 3 :

1. le poste «Client 1» se connecte à «Passerelle SSH» ;
2. depuis le terminal ouvert sur «Passerelle SSH», l'utilisateur ouvre une connexion sur «Serveur cible».



FIGURE 1 – Sans pivot

La machine «Serveur cible» n'est pas forcément accessible depuis l'extérieur.

Cette méthode ne permet pas d'exporter les applications graphiques (via l'option '-X') ou d'effectuer des copies de fichiers directement sur le serveur cible.

Essayez de vous connecter en utilisant cette méthode sur la machine de vos voisins en passant par une autre machine de la salle.

1.6.2 Redirection de port 端口重定向

La redirection de port permet de connecter le port X d'une machine distante sur le port Y de la machine locale au travers d'une tierce machine comme l'illustre la figure 2 page 3. Dans ce cas :

1. le poste «Client 1» se connecte à «Passerelle SSH» pour lui demander de créer un tunnel redirigeant le port X du serveur cible sur le port Y de la machine locale ;
2. la passerelle SSH assure la mise en place de ce tunnel qui restera actif tant que la connexion restera ouverte ;
3. à l'aide d'un autre terminal, le poste client se connecte sur l'entrée du tunnel qui redirige le trafic directement sur le port du serveur cible.

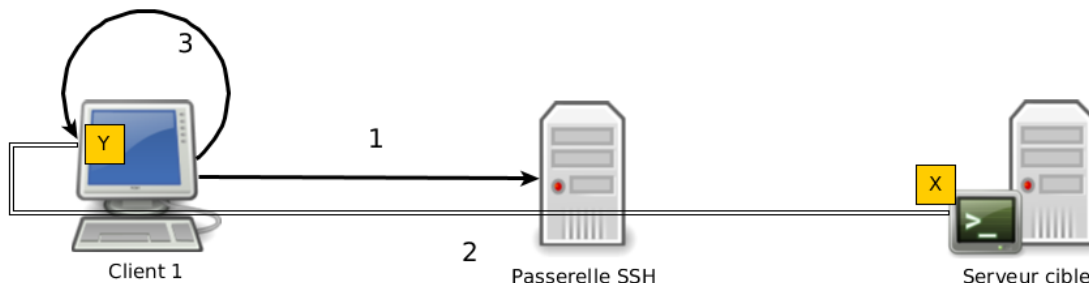


FIGURE 2 – Redirection de ports

NB : En simple utilisateur, le port Y doit être un port non privilégié (donc supérieur à 1024).

L'exemple suivant redirige le port ssh (22) de la machine 22.dptinfo.ens-cachan.fr sur le port 2222 de la machine locale au travers du serveur SSH ssh.dptinfo.ens-cachan.fr :

```
ssh -L 2222:22.dptinfo.ens-cachan.fr:22 login@ssh.dptinfo.ens-cachan.fr
```

Dans un second terminal, il est alors possible de se connecter sur la machine 22 en empruntant le tunnel

```
ssh -p 2222 login@localhost
```

Connectez vous sur la machine de votre voisin en utilisant une redirection de port SSH sur le port 1000 puis le port 2000. Que ce passe-t-il ?

Utiliser la redirection précédente pour vous connecter sur votre machine.

1.6.3 Le pivot

跳板 (Pivot) 方法

La méthode du pivot, illustrée figure 3 page 4, permet d'accéder à une machine au travers d'une ou plusieurs autres de manière quasi transparente.

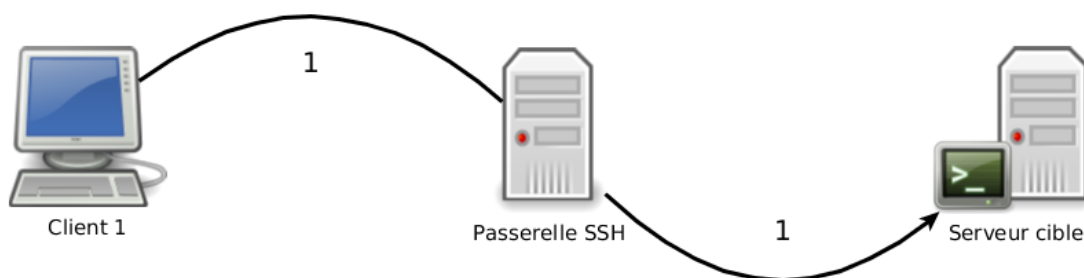


FIGURE 3 – Méthode du pivot

Au contraire de la connexion par rebond, l'utilisation de la passerelle est transparente pour l'utilisateur. La connexion étant redirigée à la manière de la redirection de port, l'export X fonctionne.

Via le fichier de configuration de ssh

L'option «ProxyCommand», ajoutée à la définition d'un alias dans le fichier de personnalisation du client ssh, permet de spécifier la machine utilisée comme pivot.

Host <alias_machine>	定义了如何通过一个跳板机 (pivot, 也称为跳板服务器
Hostname <machine.cible>	或中继服务器) 来连接到目标服务器
User <login_sur_machine_cible>	
ProxyCommand ssh <login>@<machine.ssh.pivot> -W %h:%p	通常用于 .ssh/config 文件

où :

- <alias_machine> le nom qui sera utilisé pour appeler cette configuration ;
- <machine.cible> machine sur laquelle nous souhaitons arriver ;
- <login_sur_machine_cible> login à utiliser sur la machine cible, si non précisé, login courant utilisé ;
- <login>@<machine.ssh.pivot> paramètres de connexion sur la machine pivot.

Consulter la page de manuel de «ssh_config» pour vous documenter sur l'option «-W».

Configurez un alias vous permettant de vous connecter sur votre machine au travers du serveur SSH du département d'informatique.

Ajouter l'utilisation de la clé SSH «secure» précédemment générée.

NB : Vous pouvez utiliser les alias lors de la création de vos alias.

Via les nouvelles fonctionnalités d'ssh

-W 参数指定了一个内建的“netcat模式”。该参数后面应当跟随主机名和端口号 (格式为 host:port), SSH客户端会创建一个到指定主机和端口的TCP连接。

Une version récente d'OpenSSH offre une nouvelle option '-J' qui permet de spécifier un pivot lors d'une connexion.

La configuration précédente peut alors s'écrire

```
ssh -J <login>@<machine.ssh.pivot> <login_sur_machine_cible>@<machine.cible>
```

Testez la connexion à la machine de votre voisin au travers du serveur SSH du département.

NB : Vous pouvez également utiliser l'option «ProxyJump <login>@<machine.ssh.pivot>» dans votre fichier de configuration. Cette option a été introduite dans OpenSSH 7.3.

1.7 Proxy SOCKS

SOCKS代理

Vous pouvez utiliser un serveur SSH comme serveur proxy (serveur mandataire) comme illustré sur la figure 4 page 5, c'est à dire que votre trafic web passera par le serveur SSH et que vous naviguerez comme si vous vous trouviez dans les murs de l'université.

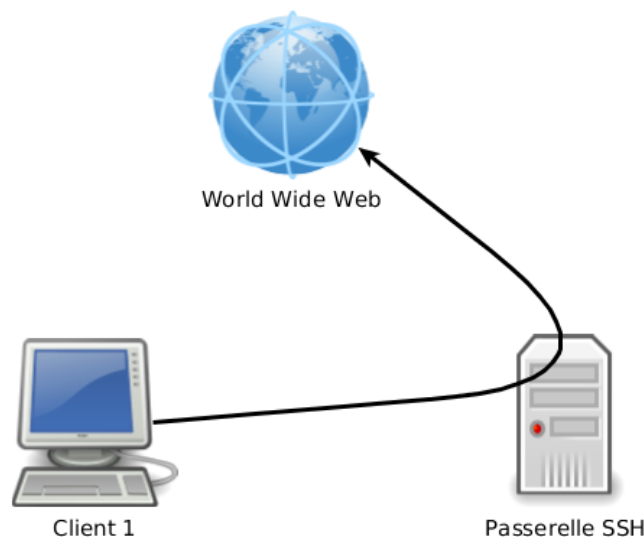


FIGURE 4 – Proxy SOCKS

- Cherchez sur Google, avec Firefox, un site affichant votre adresse IP ;
- Dans un terminal utiliser l'option «-D <port_non_reserve>» pour créer un proxy local (consulter le manuel de ssh pour voir comment utiliser l'option) ;
- Configurer votre navigateur internet pour utiliser votre proxy local ; avec Firefox :
 - Rendez-vous dans «préférences» puis «Avancé» (page about :preferences#advanced) et sélectionnez l'onglet «réseaux» ;
 - Configurez le mode de connexion au réseau en cliquant sur «configuration»
 - Dans la nouvelle fenêtre activez «Configuration manuelle» et renseignez les champs «SOCKS Host» = localhost et «Port» = <port_non_reserve> spécifié précédemment.
 - Validez par «Ok»
- Rafraîchir la page du site affichant votre IP. Que constatez vous ?
- Fermez la connexion ssh ouverte puis rafraîchissez la page web affichant votre IP. Que se passe-t-il ? Pourquoi ?

1.8 Multiplexeur de terminal

L'outil «tmux» vous permet d'ouvrir plusieurs instances du shell dans un même terminal et donc via SSH par exemple.

- Lancez «tmux» dans un terminal.
- Lancez la commande «top».
- Ouvrir une nouvelle instance du terminal via «Ctrl+b» (pour signaler que nous envoyons la commande à «tmux») puis «c» (pour create)
- Listez le contenu du répertoire courant
- Retourner sur le shell executant "top" via «Ctrl+b» puis «p» (previous). Utilisez «Ctrl+b» puis «n» pour l'écran suivant (next).
- «Splittez» l'écran verticalement «Ctrl+b» puis «|».
- «Splittez» l'écran horizontalement «Ctrl+b» puis «%».
- Détachez ce tmux du terminal «Ctrl+b» puis «d».
- Ré attachez votre tmux au terminal «tmux a».
- Vérifiez que «top» fonctionne toujours.

Le manuel de tmux et Google vous donneront toutes les astuces du fonctionnement de ce programme.

2 Les ICP ou comment gérer des cartes d'identité digitales

Notes sur les acronymes :

- **ICP** une infrastructure à clef publique 一个框架和一套技术标准, 用于创建、管理、分发、使用、存储和撤销数字证书。
- **PKI** Public Key Infrastructure (anglais de ICP)
- **AC** Autorité de certification 负责发行和管理安全证书的受信任机构。
- **CA** Certificate Authority (anglais de AC)
- **CRL** Certificate Revocation List 由 CA 发布的一种清单, 列出了所有被撤销的数字证书。
- **OCSP** Online Certificate Status Protocol 用于即时验证数字证书状态的协议。
- **CSR** Certificate Signing Request 由证书申请者创建的包含公钥的请求文件, 用于向 CA 申请数字证书。

2.1 openssl - un outil très utilisé

Pour éviter de vous perdre dans les noms de fichier, vous systématiserez le nommage sous la forme **entite.type_du_fichier.pem** où :

- **entite** est l'entité concernée par le fichier (client, AC, ...)
- **type_de_fichier** est la nature de l'élément inclus dans le fichier. Par exemple :
 - **key** pour un clef asymétrique ou **.key.rsa** pour une clef RSA
 - **req** (request) ou **csr** (certificate signing request) pour une requête de certificat
 - **cert** ou **x509** pour un certificat
 - **certs** ou **chain** pour un ensemble de certificats
 - **crl** pour une liste de revocation de certificat. Elle pourrait être suivant d'un numéro de liste.
- **".pem"** est le format du fichier (que l'on peut en général fixer avec -inform ou -outform). L'autre format est **".der"**.

Les fichiers manipulés par openssl, on soit le format **".pem"** soit le format **".der"**. En fait ces deux format sont les même mais l'encodage est différent. Le format **.pem** est un encodage à base de texte/caractères lisibles alors que le **.der** est un encodage binaire (texte non lisible) mais plus compacte.

Les fichiers **.pem** ont tous la même structure :

```
-----BEGIN xxxx-----
...contenu en base64...
-----END xxxx-----
```

Où **xxxx** est ce qui est contenu dans le fichiers (par ex : PRIVATE KEY, CERTIFICATE, CERTIFICATE SIGNING REQUEST, ...). Il existe d'autres format de représentation ou pour la conversion (les pkcs#xx).

2.2 La commande openssl

La commande **openssl** s'utilise de deux façons : soit en mode shell en tapant "**openssl**" soit en tapant "**openssl commande [-option param] ...**".

Pour obtenir de l'aide : **openssl commande -h**

Les commandes principales :

- **version**, **ciphers**, **speed**, **errstr** donnent des infos sur openssl
- **dsa**, **dsaparam**, **rsa**, **gensa**, **genrsa** permettent la manipulation des clefs asymétriques
- **req** permet la manipulation des requêtes de certificats
- **x509** permet la manipulation des certificats
- **ca** permet de jouer le rôle de l'autorité (signature, CRL, ...)
- **pkcs7**, **pkcs8**, **pkcs12**, **verify** permet de manipuler des formats de fichiers liés aux certificats
- **s_client**, **s_server** permet de lancer des clients ou des serveurs TLS avec certificats
- **dgst**, **enc** Création d'un hache ou le chiffrement symétrique de données

2.2.1 question

Lancer les commandes **openssl ciphers -v 'HIGH'** et **openssl speed**. Décrivez son résultat
LAISSER TOURNER EN FOND ET AVANCER SUR LE TD.

2.3 Création de l'AC

Pour la création de l'AC, il faut créer un répertoire **~/pki/ac**. Puis nous allons créer les premiers éléments de l'AC : ceux nécessaires à l'aspect METIER !

2.3.1 Question

Quels sont les 2 éléments métiers requis pour faire une ICP ? Créez les dans le répertoire **~/pki/ac** !

私钥：用于 CA 的签名操作。

2.3.2 Question 根证书：这是由 CA 自签的证书，用来验证其他证书。

Pourquoi n'y a-t-il qu'un seul fichier pour la clef asymétrique ? Démontrer votre propos en proposant un moyen d'obtenir la clef publique.通常，非对称密钥对包括一个私钥和一个公钥。私钥应该保密，而公钥可以公开。从私钥可以导出公钥，但反之则不行。

Pourquoi vouloir chiffrer la partie privée de la clef ? Quelle(s) contrainte(s) cela impose-t-il ? Quel(s) avantage(s) cela a-t-il ?加密私钥是为了保护密钥不被未授权访问。这会带来一些使用上的不便，例如每次使用时都需要输入密码，但提供了更高的安全性。

Maintenant intéressons-nous à l'aspect technique (non fonctionnel). La configuration est stockée dans un fichier spécifique que vous allez copier pour ne pas modifier celui du système. Pour cela vous allez utiliser la commande **openssl ca**. La première ligne indique "**Using configuration from ...**".

2.3.3 Question

Copier ce fichier et éditer la section "**[CA_default]**" de la copie pour : le faire pointer sur votre répertoire, sur votre clef, sur votre certificat racine. Créer le fichier **index.txt**, les sous-répertoires nécessaires. Exécuter la commande "**openssl ca**" pour utiliser ce fichier et vérifier qu'elle n'indique aucune erreur à l'exécution.

VOTRE CA EST NORMALEMENT PRETE A FONCTIONNER.

2.4 Regarder un peu les autres AC

2.4.1 Questions

Regarder un peu les certificats racines dans chrome ou firefox.

Trouver et Regarder un peu les certificats racines dans votre système

Tester **openssl s_client** avec google et microsoft. Récupérer une CRL. Voir la CRL textuellement.

Comparer à votre certificat d'AC ?

2.5 Jouons au client

Maintenant que chaque étudiant à son AC (à priori fonctionnelle), il faut se mettre en binôme. Chacun va créer une REQUETE de certificat et l'envoyer à son binôme pour qu'il l'a signe avec sa propre AC. Et donner ce certificat à son client.

2.5.1 Questions

Générer la requête. Envoyer la à votre binôme.

2.5.2 Question

Justifier. Quelle sont les solutions possibles ?

2.6 Revocation d'un certificat

En tant que AC, vous constatez que votre premier client ne se comporte pas correctement. Il existe deux méthode pour gérer les certificats révoqués :

- **CRL** : le serveur génère une liste de certificat régulièrement que peut télécharger tout client. Cela nécessite un serveur pour télécharger ce fichier.
- **OCSP** : le serveur répond au demande de vérification de certificat. Les clients demandent si tel ou tel certificat est valide ou non.

2.6.1 Question

D'après vous et vos précédents essais, quelle peut-être le justification d'une révocation de certificat ?

L'URL de téléchargement des fichiers CRL est en général sous la forme "**HTTP**://" (donc sans connexion chiffrée et authentifiée). Pourquoi ?

2.6.2 Question

Révoquer le certificat et générer votre première CRL. Vérifier si le certificat que vous avez récupéré est révoquer au moins auprès du serveur OSCP.

2.7 Utilisation d'un certificat

Nous allons maintenant générer un certificat pour une interaction client WEB - serveur WEB. Pour les certificats de service (machine serveurs), ils doivent avoir une structure particulière. Les certificats doivent avoir comme DN leur adresse IP ou leur nom DNS. Mais depuis quelques années, il doivent aussi un attribut "alias" ayant les valeurs du DN. Pour cela vous regarder l'option "**-addtext**" ou les fichiers templates pour les CSR.

2.7.1 Question

Dans ce cadre là, dites qui est serveur de qui et qui est client de qui.

2.7.2 Question

Générer la CSR pour le serveur WEB.

Faire signer le certificat pour une autorité. Récupérer le certificat du serveur et celui de l'AC qui a signé le certificat. De même, vous devrez activer l'option "**copy_extensions = copy**" dans votre fichier "**openssl.cnf**".

2.7.3 Question

Faite en sorte que le serveur authentifie le client. C'est à dire qu'il n'accepte que des connexion provenant d'un client ayant une certification de l'AC.

Générer un certificat pour le client et tenter la connexion. Pourquoi faut-il le certificat et la clef ?

2.7.4 Question

Revoquer le certificat du client. Générer une nouvelle CRL. Relancer le serveur en pointant sur la CRL. Tenter la connexion avec un client et vérifier le refus de connexion.

2.8 Signature d'un fichier avec une clef asymétrique et openssl

La signature peut se faire avec openssl mais il existe aussi d'autres outils comme gpg qui peuvent faire la même chose.

2.8.1 Question

Rappeler la définition de la signature électronique avec des CS asymétriques ? Existe-il l'équivalent avec des CS symétriques ?

En utilisant la commande **dgst** de openssl, créer une signature pour le fichier **/usr/bin/ls**. Vérifier la. Comparer votre signature avec celle de vos voisins.

Calculer un hachage sur le fichier **/usr/bin/ls**. Comparer le hachage avec votre voisin.